

1. Traditional Security vs Zero Trust

Before understanding Zero Trust, it helps to compare two approaches.

Traditional perimeter security

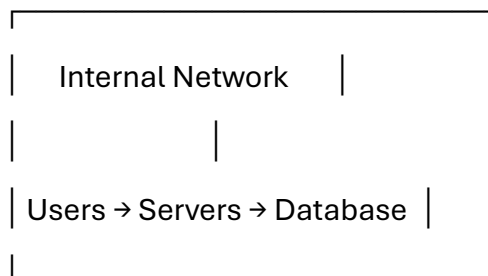
Imagine an office surrounded by a security fence.

Internet

↓

[Firewall]

↓



The assumption is roughly:

Outside = dangerous

Inside = trusted

Once a user gets inside the network, they may have relatively broad access.

Problem

Suppose an employee's laptop is compromised.

An attacker may gain access to the internal network and attempt to move from:

Employee laptop → File server → Database → Other systems

This is known as **lateral movement**.

2. Zero Trust Architecture

Zero Trust changes the assumption.

Instead of:

"You are inside the network, so we trust you."

It uses:

"Prove that you should have access to this resource."

For example:

User

↓

Identity Verification

↓

Device Verification

↓

Access Policy

↓

Specific Application

↓

Specific Data

Even if the user successfully logs in, access is still controlled.

3. Principle 1: Explicit Verification

The first principle in the image is:

Explicit Verification

This means that authentication and authorisation should consider relevant information before granting access.

The system may evaluate:

- User identity
- Password
- Multi-factor authentication
- Device health
- Location
- Time
- Network

- Application
 - Risk level
 - Requested resource
-

Real-world example: Microsoft 365

Imagine an employee normally accesses company email from Singapore using a managed company laptop.

One day, a login attempt occurs from another country using an unfamiliar device.

The system can evaluate:

Is this really the employee?

It may request additional authentication or restrict access depending on the organisation's security policies.

Simple example

Normal:

Known user + managed laptop + MFA + normal location
→ Access granted

Suspicious:

Known user + unknown device + unusual location
→ Additional verification / access restriction

The important point is:

Knowing the username and password is not automatically enough.

4. Authentication vs Authorisation

Students often confuse these two concepts.

Authentication

Who are you?

Example:

Username + password + MFA

Authorisation

What are you allowed to access?

Example:

You are an employee, but you are not authorised to access the Finance database.

So:

Authentication = identity

Authorisation = permission

Zero Trust uses both.

5. Principle 2: Least Privilege Access

The second principle is:

Least Privilege Access

This means users should receive **only the access they need to perform their work.**

Imagine a school.

A lecturer may need access to:

- student attendance
- teaching materials
- assessment records

But the lecturer may not need access to:

- payroll
- employee salaries
- bank accounts
- financial reports

Therefore:

Lecturer

↓

Teaching systems

✓ Access

Finance database

X No access

6. Just-In-Time (JIT) Access

The image mentions **Just-In-Time access**.

This means access can be granted **only when it is required and for a limited period**.

Example

An IT administrator needs to repair a production database.

Instead of giving the administrator permanent administrator privileges:

Request access → Approval → Admin access for 30 minutes → Access automatically removed

This reduces the period during which powerful credentials can be abused.

7. Just-Enough-Access (JEA)

Just-Enough-Access means giving the user **only the specific permissions required**.

For example, an IT technician needs to restart a server.

They might be allowed to:

Restart service ✓

But not:

Delete database X

Create administrator account X

Change security policies X

The objective is to reduce unnecessary privileges.

8. Real-World Example: Hospital

Consider a hospital information system.

Different employees require different access.

Role	Patient Records	Billing	HR
Doctor	✓	Limited	X
Nurse	✓	X	X
Finance Staff	Limited	✓	X
HR Staff	X	X	✓

IT Administrator Controlled technical access Controlled Controlled

A Zero Trust approach does not simply say:

"This employee works for the hospital, therefore they can access the network."

Instead:

Who are they? What are they trying to access? Why do they need it? Is their device trusted? What is the current risk?

9. Principle 3: Assume Breach

The third principle is:

Assume Breach

This means an organisation operates under the assumption that **a security breach could already have occurred or could occur at any time.**

It does not mean:

"We know we have been hacked."

It means:

"We design our security controls on the assumption that an attacker may eventually get through one layer."

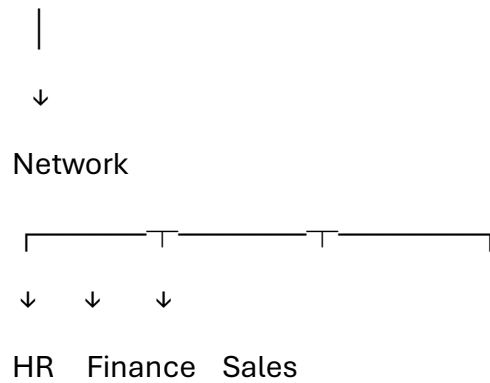
This changes the security strategy.

10. Network Segmentation

One way to implement "Assume Breach" is through **segmentation**.

Imagine a company network divided into:

Internet



If an attacker compromises a Sales computer, segmentation can make it harder to directly access the Finance system.

This limits the **blast radius**.

Blast radius

The blast radius refers to **how much damage an incident can cause after a security breach**.

Without segmentation:

One compromised account → potentially many systems

With segmentation:

One compromised account → limited systems

11. Microsegmentation

The diagram specifically mentions:

Application Microsegmentation

Microsegmentation goes further by controlling communication between individual applications, workloads or resources.

For example:

Web Server



Application Server



Database

The database might only accept connections from the application server.

A compromised employee laptop cannot simply connect directly to the database.
This creates additional security boundaries.

12. End-to-End Encryption

The image also mentions encryption.

Encryption transforms readable information into protected data.

For example:

Original:

Student Name = John

↓ Encryption

Encrypted:

8fA7x!92K...

Only an authorised system or person with the appropriate cryptographic capability can decrypt it.

Real-world example

When you use online banking, sensitive information should be protected while being transmitted between your device and the bank's systems.

Encryption helps reduce the risk of someone intercepting readable information.

13. AI-Based Threat Detection

The image also refers to:

Real-time AI threat analytics

AI and machine-learning techniques can help security teams analyse large volumes of events.

For example, an employee normally:

Logs in 8:30 AM
Uses Singapore IP address
Accesses 5–10 files

Suddenly:

2:00 AM login
Unusual location
Downloads 5,000 files

The system can identify this as an unusual pattern and trigger an alert.

Importantly, **AI does not automatically prove that an attack has occurred**. It can identify suspicious behaviour for further investigation or support automated security responses according to defined policies.

14. Understanding the Diagram on the Right

The diagram shows several components working together.

Users

People who need access to organisational resources.

Examples:

- employees
- managers
- contractors
- students
- administrators

Devices

The devices used by those users.

Examples:

- laptops
- smartphones
- tablets
- company computers

The organisation may check whether the device is:

- registered
- patched
- encrypted
- protected by security software
- compliant with organisational policy

15. Policy Enforcement Point

The **Policy Enforcement Point (PEP)** is an important component.

Think of it as a **security gatekeeper**.

A user requests:

"I want to access the finance application."

The policy enforcement mechanism evaluates the request according to organisational policies.

For example:

User identity ✓

MFA ✓

Managed device ✓

Device security ✓

Location ✓

Requested application ✓

Risk level Low

↓

Access Granted

Another request might be:

User identity ✓

MFA ✓

Unknown device X

High risk X



Access Denied

16. Cloud Software Services

Modern businesses increasingly use cloud applications such as:

- Microsoft 365
- Google Workspace
- Salesforce
- cloud accounting systems
- cloud-based CRM
- cloud-based HR systems

Zero Trust is particularly relevant because users may access these services from:

- home
- office
- mobile devices
- other countries
- public networks

Therefore, security cannot depend solely on a traditional office network perimeter.

17. Software-Defined Network

A **Software-Defined Network (SDN)** uses software-based controls to manage network connectivity and policies.

Instead of relying only on traditional hardware-based network configuration, organisations can dynamically apply policies.

For example:

Employee laptop → Allowed to access HR application

but:

Same laptop → Not allowed to access database server directly

The access decision can be based on organisational policy.

18. Complete Real-World Example: A School

Let's put all three Zero Trust principles together.

Imagine a school has:

- Student Management System
- LMS
- Finance System
- HR System
- Cloud storage
- Staff laptops

Scenario

A lecturer wants to access the Student Management System.

Step 1 — Explicit Verification

The system checks:

Who is the lecturer?

Is MFA enabled?

Is the device recognised?

Is the device secure?

Where is the login coming from?

Step 2 — Least Privilege

The lecturer receives:

Student academic records ✓

But:

Payroll X
Finance database X
HR records X

Step 3 — Assume Breach

The school's systems are segmented.

Even if the lecturer's laptop becomes compromised, the attacker should not automatically have access to:

Finance → HR → Management systems

Additional monitoring and controls can detect suspicious behaviour.

Result

The school does not simply trust the lecturer because:

"They are an employee."

Instead, it continuously evaluates:

Identity + Device + Context + Permission + Resource + Risk

19. Zero Trust vs Traditional Security

Traditional Perimeter Model	Zero Trust
Trust inside network	Do not automatically trust
Focus on network boundary	Focus on identity, devices, applications and data
Login may provide broad access	Access is limited to required resources
Internal traffic may receive more trust	Internal traffic is also controlled
Static security controls	Continuous evaluation
Large network zones	Microsegmentation
Protect the perimeter	Protect each resource

20. The Three Principles to Remember

1. Explicitly Verify

"Prove who you are and that your request is legitimate."

Check:

Identity + Device + Context + Risk

2. Least Privilege

"Give users only the access they need."

Use:

JIT + JEA + Role-based access

3. Assume Breach

"Design the system as if a breach could happen."

Use:

Segmentation + Microsegmentation + Encryption + Monitoring + Threat Detection

21. Easy Formula for Students

A useful way for students to remember Zero Trust is:

VERIFY → LIMIT → CONTAIN

VERIFY

Who are you? Is your device trustworthy? What are you trying to access?

↓

LIMIT

Give you only the permissions required.

↓

CONTAIN

If something goes wrong, prevent the attacker from reaching everything else.

So the fundamental Zero Trust mindset is:

Never automatically trust. Verify every access request, provide only the necessary access, and limit the damage if an account or device is compromised.